Safety Architecture

Çıktı: Safety Function Map

Ad Soyad: Grup: Tarih: 25.10.2026

Kapsam ve veri ayrımı: Kaynak PDF'nin LAB 1-4 bölümleri (s. 2-5) uyarlanmıştır. [1] üretici verisidir; emniyet rölesi/PLC, STO, kapak kilidi, ışık perdesi, PLC modeli ve uzak erişim donanımı açıklanmamıştır. Aşağıdaki emniyet zinciri **öneridir**; mevcut makinenin doğrulanmış devresi değildir.

Makine bağlamı [1]: Ahşap kapı, kapak ve mobilya kenarlarında ham/astar zımparası; bir disk fırça ve iki orbital motor. Konveyör ve zımpara hızları dokunmatik ekrandan ayarlanır; ünite ve üst baskı tekeri konumları manueldir. İlerleme: 1-10 m/dk; toz emiş ihtiyacı: 1000 m³/sa.

Normal yol (kavramsal): Operatör/HMI → standart kontrol → konveyör + orbital motorlar + disk fırça.
Önerilen ayrı emniyet yolu [EMN]: Acil durdurma + erişim koruyucusu → emniyet rölesi/PLC → doğrulanmış durdurma ve enerji kesme → tehlikeli hareketin bitmesi. [EMN] tüm giriş-mantık-çıkış zinciridir; yalnız PLC değildir.

1. Tehlike ve zarar
Dönen zımparaya kapılma/aşınma; konveyör-baskı tekerinde sıkışma ve ezilme; parçanın fırlaması. Ahşap tozu solunum ve yangın tehlikesi doğurabilir. Bunlar işlemden çıkarılan tehlikelerdir.

2. Emniyet fonksiyonu
SF-01: Koruyucu açıldığında tehlikeli hareketi erişimden önce durdurmak ve yeniden başlamayı engellemek. SF-02: Acil durdurma talebinde güvenli duruş. Toz emiş kaybına ilişkin duruş ihtiyacı ayrıca değerlendirilir.

3. Emniyetle ilgili kontrol sistemi
Şemada [EMN] olarak işaretlenen algılayıcı, emniyet mantığı ve son anahtarlama elemanlarıdır. Gerçek bileşenler elektrik şeması ve saha incelemesiyle belirlenir.

4. Normal PLC / Safety PLC farkı
Standart PLC üretimi yönetir. Emniyet kontrolörü, uygun mimari ve doğrulamayla arızada risk azaltmayı sağlar. HMI'deki normal durdurma komutu emniyet fonksiyonunun yerine geçmez.

5. PLr / SIL neden gerekli?
Fonksiyonun gerekli risk azaltma güvenilirliğini tanımlar. ISO 13849-1 veya IEC 62061 yaklaşımıyla fonksiyon bazında belirlenir [2]. Maruziyet ve kaçınma verileri yoktur; bu föyde PLr/SIL sayısı atanmaz.

6. Güvenli durum
Tehlikeli dönüş ve besleme durmuş; parça güvenle tutulmuş; beklenmedik başlatma engellenmiş durumdur. STO tek başına anında duruş sağlamaz [3]. Artık dönüş için duruş süresi/erişim doğrulanır; bakımda enerji izolasyonu yapılır.

7. Dijital bağımlılıklar
Varsa emniyet yazılımı, firmware, I/O eşlemesi, sürücü emniyet parametreleri ve emniyet haberleşmesi. Ortak besleme/ortak hata ve reset yolu da incelenir; internet erişimi emniyet için zorunlu olmamalıdır.

8. Siber müdahale noktası
Varsa servis hesabı, mühendislik portu veya USB üzerinden kontrol/parametre değişikliği yapılabilir. Emniyetin bozulması ancak emniyet zincirine etki yolu varsa mümkündür; bu yol doğrulanmadan kesin bulgu yazılmaz.

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad: Grup: Tarih: 25.10.2026

Varsayım sınırı: Üreticide dokunmatik ekran doğrulanır [1]. PLC/sürücü türleri ve tüm ağ bağlantıları belirsizdir. Föydeki port 80, admin/admin, Wi-Fi, USB, bulut ve internete açık bakım örnekleri bu makinede tespit edilmiş zafiyetler değildir. Aşağıda yalnız eğitim senaryosu ve hedef gereksinim olarak ele alınır.

Görev A - 1. Varlıkların önerilen bölgeleri [4]

Bölge	Varlıklar / gerekçe
Z1 - Makine kontrolü	HMI, varsa üretim PLC'si ve ağ bağlantılı sürücüler: üretim komutları ve yerel proses verileri.
Z2 - Emniyet	Önerilen emniyet rölesi/PLC, koruyucu girişleri ve güvenli çıkışlar: kritik koruma işlevleri. Bağımsızlık doğrulanacak.
Z3 - Endüstriyel DMZ	Varsa uzak bakım ağ geçidi, jump server ve oturum kayıt sistemi: dış erişim burada sonlandırılır.
Z4 - İşletme / bakım	Yetkili bakım bilgisayarı, kimlik ve yama hizmetleri. Servis hesabı bir cihaz değil; bu erişimin kimlik varlığıdır.
Z5 - Harici ağ	Tedarikçi/servis ve varsa bulut. Wi-Fi varsa ayrı kısıtlı erişim bölgesi; USB varsa kontrollü yerel bakım arayüzü.

2. Açık bakım modülü nerede? Varsayımsal internete açık modül Z1/Z2'de doğrudan erişilebilir kalamaz. Dış erişim Z3'te denetlenmeli; modülün konumu ve bağlantıları envanterle doğrulanmalıdır.

3. Bölgeler arası geçişler ve kontroller

Conduit	Kontrol edilecek koşul
Z5 → Z3	VPN + MFA; kişisel kimlik, süreli onay ve kayıt. Doğrudan PLC/HMI port yönlendirmesi yasak.
Z4 → Z3 → Z1	Jump server; hedef/protokol/işlem izin listesi, en az yetki, yerel bakım izni; varsayılan ret.
Z1 ↔ Z2	Yalnız gerekçelendirilmiş durum bilgisi ve doğrulanmış arayüz; standart kontrol emniyeti geçersiz kılamaz. Uzak emniyet yazma/reset yolu olmamalı.
Z1 → Z3 → bulut	Yalnız ihtiyaç varsa dışa telemetri; buluttan kumanda yok. Hedef, veri ve bağlantı yönü sınırlandırılır.
USB / Wi-Fi → bakım	Varsa USB yetkilendirme ve dosya denetimi; Wi-Fi ayrı ağ, kişisel kimlik ve kontrollü geçiş.

Görev B - Uzak erişim kararı

Karar	Seçim ve nedeni
Aracı / Tünel	Jump server / VPN: kontrollü ara nokta ve şifreli bağlantı.
Kimlik / Hesap	MFA / kişisel hesap: ele geçirilen parolanın etkisini azaltır, sorumluluğu izlenebilir kılar.
Kayıt / Zamanlama	Tam oturum kaydı / varsayılan kapalı: değişiklik kanıtı; yalnız onaylı bakım penceresinde erişim.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad: Grup: Tarih: 25.10.2026

Risk kaydı varsayımı: Aşağıdaki üç senaryo saha bulgusu değildir. Bağlantı ve zafiyetler yalnız varsa geçerlidir. Puanlar kontrol öncesi eğitim tahminidir: L = gerçekleşme olasılığı, S = fiziksel şiddet, E = maruziyet; her biri 1 (düşük), 2 (orta), 3 (yüksek). S=3 ciddi/kalıcı yaralanma olasılığıdır. Bu puanlama PLr/SIL tayini değildir.

Eşikler (kaynak föyle aynı): 18-27 Kritik; 9-17 Yüksek; 4-8 Orta; 1-3 Düşük. **S=3 olan tüm senaryolar ayrıca öne alınır.**

Senaryo: kim → kapı → eylem → zincir → fiziksel sonuç	L	S	E	Skor / öncelik
R1 - Dış saldırgan → varsayımsal açık bakım modülü ve ortak hesap → kontrol parametresi/program değişikliği → yerel izin ve bağımsız yeniden başlatma engeli de etkisizse konveyör/fırça beklenmedik çalışır → müdahale eden kişinin eli sıkışır veya dönen takıma kapılır.	3	3	2	18 Kritik
R2 - Zararlı USB taşıyan bakım cihazı → varsa denetimsiz servis USB'si → sürücü/PLC ayarı değişir → izin verilen hız sınırları aşılır ve parça tutma/koruma yetersiz kalır → parça fırlar, operatörde ciddi yüz/göz yaralanması oluşabilir.	2	3	2	12 Yüksek
R3 - Yetkisiz/ele geçirilmiş mühendislik hesabı → varsa emniyet yapılandırma arayüzü → koruyucu girişi bypass edilir → kapak açıkken artık dönüşe erişim mümkün olur → elde ciddi aşınma/kapılma yaralanması. Nadir bakım erişimi varsayılmıştır.	1	3	1	3 Düşük*

Puanların dayanağı ve belirsizlik

R1'de L=3, yalnız doğrudan açık ve zayıf kimlikli erişim varsayımına dayanır. R2'de L=2, dönemsel bakım dosyası aktarımına dayanır. R1/R2 için E=2 aralıklı operatör maruziyetidir. R3'te L=1 ve E=1, nadir ve sınırlı bakım varsayımıdır. S=3, her üçünde kalıcı fiziksel zarar olasılığı nedeniyledir. Gerçek kullanım gözlemleriyle yeniden puanlanır.

1. En yüksek öncelik: R1; varsayılan açık erişim ile beklenmedik hareket zinciri birleştiğinden skor 18'dir. Bağımsız emniyet doğrulanırsa bu zincirin kesildiği ve kalan risk ayrıca kaydedilir.

2. S=3 fakat düşük skorlu senaryo: R3, 1 × 3 × 1 = 3. Sayısal sınıfı Düşük kalır; **"S=3 - zorunlu öncelikli inceleme"** etiketiyle üst inceleme listesine alınır. Düşük skor kabul kararı sayılmaz.

Aksiyon, sorumlu ve kapanış kanıtı

Kayıt / sorumlu	Önlem ve kabul kanıtı
R1 - OT sorumlusu + üretici	Açık erişimi kaldır; süreli onay/MFA uygula. Bağlantı taraması, erişim logu ve yetkisiz komutun güvenli durumu bozamama testi.
R2 - Bakım + otomasyon	Onaylı bakım medyası, parametre sınırları ve değişiklik kontrolü. Sürüm/parametre karşılaştırması; hız ve parça tutma doğrulaması.
R3 - Emniyet yetkilisi	Emniyet değişikliklerini ayrı yetkilendir; bypass ve yeniden başlatmayı doğrula. İmzalı konfigürasyon kaydı ve fonksiyon test raporu.

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad: Grup: Tarih: 25.10.2026

Mevcut durumun sınırı: İnternet bağlantısı ve uzak bakım modülü üretici sayfasında belirtilmez [1]. Gerçek ağ şeması bilinmiyor. Bu nedenle “mevcut” alanı gerçek bulgu ve föyün eğitim varsayımı olarak ayrı doldurulmuştur; hedef, karşılanması gereken gereksinimleri gösterir.

Görev A - Mevcut → hedef

MEVCUT / bilinen ve varsayılan	HEDEF / beş ilke
Doğrulanan: Hız ayarı için dokunmatik ekran vardır. PLC ağı, emniyet kontrolü, modem, kullanıcı hesapları ve kayıtlar bilinmiyor. Eğitim varsayımı: İnternet → doğrudan bakım modülü → makine kontrolü. Emniyet ağına geçiş olup olmadığı belirsiz.	1. Kontrollü ara nokta: Dış bakım yalnız DMZ/jump server üzerinden; PLC/HMI’ye doğrudan internet erişimi yok. 2. Güvenli kimlik ve kanal: VPN + MFA + kişisel hesap, en az yetki. 3. Süreli yerel izin: Varsayılan kapalı; iş emri, makine başında onay ve otomatik süre sonu. 4. İzlenebilirlik: Oturum ve değişiklik kaydı, zaman eşleme, kayıt bütünlüğü ve erişim denetimi. 5. Emniyet bağımsızlığı: Uzak komut emniyet fonksiyonunu bypass edemez; uzaktan reset/yeniden başlatma engellenir.

Hedef akış (kavramsal):
Yetkili servis → VPN + MFA → Z3 DMZ / jump server → izinli bakım geçişi → Z1 kontrol.
Yerel yetkili: iş emri + süreli bakım onayı. Kayıt: oturum + değişiklik izi.
Z2 emniyet: Uzak bakım yolundan emniyet yazma/bypass/reset yetkisi yok; koruyucu talebi üretim kontrolünden bağımsız uygulanır.

Görev B - Functional safety köprüsü

1. Saldırgan içeri girerse emniyet etkilenir mi?

Mevcut makine için şema ve test olmadan yanıt verilemez. Hedefte, standart kontrolün ele geçirilmesi emniyet duruşunu ve yeniden başlatma engelini geçersiz kılamamalıdır. Ortak besleme, ağ, sürücü ve mühendislik erişimleri ortak nedenli etki bakımından incelenmelidir. Siber erişim önlemleri tek başına bu bağımsızlığın kanıtı değildir.

2. Gereksinim (çözümden bağımsız):

KR KZM 3 Speedy’de tehlikeli hareketi durduran koruyucu/emniyet zinciri, uzak bakım kanalının veya standart kontrolün ele geçirilmesi, hatalı komutu ya da iletişim kaybı halinde gerekli duruş ve yeniden başlatmayı önleme işlevini sürdürmelidir. Uzak kullanıcı bu zinciri devre dışı bırakamamalı, emniyet parametrelerini değiştirememeli veya reset verememelidir. Erişim, risk değerlendirmesinde belirlenen duruş/erişim süresi koşullarını sağlamalıdır. Işık perdesi varlığı doğrulanmadığından gereksinim gerçek koruyucu tipine göre uyarlanır.

Doğrulama kanıtı: Gerçek bileşen envanteri ve elektrik/ağ şeması; risk değerlendirmesi; ölçülmüş duruş süresi; koruyucu, haberleşme kaybı, enerji geri gelmesi ve yetkisiz uzaktan komut testleri. Reset hareket başlatmamalı; tekrar çalışma ayrı yerel başlatma gerektirmelidir [3].

Kaynaklar ve kullanım notu

[1] Karabudak Makine, KR KZM 3 Speedy ürün sayfası (erişim: 25.10.2026):
karabudakmakine.com / KR KZM 3 Speedy
[2] Pilz, Standards Functional Safety and Risk Assessment (1003920-EN-06).
[3] Rockwell Automation, Safety-AT196A-EN-P, Nisan 2022, s. 5 (STO/duruş ve tekrar başlatma ilkesi).
[4] ISA, ISA/IEC 62443 Series of Standards; ISASecure/ISAGCA, IIoT System Implementation and Certification, Ek A.2.
Şablon: Kullanıcının sağladığı laboratuvar PDF’si, LAB 1-4. Eğitim çalışmasıdır; sahada ölçüm veya uygunluk belgesi yerine geçmez.